Technical standard for computer security
Evaluation of the DICT

PSA-STSSI_003	validation 25/02/2021

Synthesis

The valorization of the criteria Availability, Integrity, Confidentiality and Traceability (DICT) of an application is a mandatory element of any computer project and constitutes one of the first deliverables of the preliminary study. The analysis is conducted by considering the interdependences with the other IT applications constitutive of the information system.

This valorization determines the risk reduction measures to implement by applying the PSA-DSSI_04 directive, that the service and the storage are supplied by the DDCE or by a third party.

Table of contents

1 Subject of the document 1
2 General Scale of impacts 2
3 Availability criterion 3
4 Integrity criterion 3
5 Confidentiality criterion 4
6 Traceability criterion 5
6.1 Explanation 5
6.2 Help for the valorization of the Traceability criterion 5
7 Consideration of personal data 7
8 References 7
9 Reviews 8

1 Subject of the document

This document allows to synthetize the need for security of an IT application, based on the estimated consequences of an attack on availability, integrity and confidentiality of its contents (processed data and treatment process), as well as failure to comply with traceability requirements.

For these criteria Availability, Integrity, Confidentiality and Traceability (AICT), it establishes the thresholds between the four levels identified in case of occurrence of one of the risks taken into account in the analysis done during the project. The retained scales are derived from the documents « The risk management Device of the Group » and Operating group « Control of sensitive information ».

This valorization of the security need is validated by the MOA Person in charge of the concerned Job. It is updated depending on developments in the employment concept and systematically verified during the applicative developments.

2 General Scale of impacts

This grid issued from the document « The risks management Device of the Group » gives the appreciation elements of the level of impacts of a risk from their consequences according to 4 axes: economic axis preferred whenever possible, and the axes « client-image », legal and « human relations ».

Impact Level		1-Weak	2-Moderate	3-Strong	4-Critical
Nature of impact for the Group (and / or)	**Economic**	Lower impact to 1 M€	Impact between 1 and 10 M€	Impact between 10 and 50 M€	Impact greater than 50 M€
	Client - Image	Negative « Buzz » without lasting effect	Negative « Buzz » with lasting consequences	Withering of the trust of customers, partners, authorities and market	Fall of customer confidence, partners, authorities and market
	Legal	Consumer litigations	Civil liability of the engaged company in court	Individual criminal responsibility of a leader excluding corporate officers; anticompetitive behavior	Criminal liability of corporate officers or legal person (PSA Group), nullity actions
	HR	Breach safety/health regulations with no other consequences	Alteration of the social climate; safety or health incident likely to affect human health but without result; offset of the adequacy of human resources with business needs	Damage to the health and safety of persons without lasting consequences; or conflictual social situation; other breaches of the Code of Ethics; strong offset of the adequacy of human resources with business needs	Damage to the health and safety of people with fatal or lasting consequences; long term social conflict; fraud or collusion; strong offset of the adequacy of human resources with business needs

This generic scale should be used to value the three usual criteria specific to information systems; it is enriched below for availability and confidentiality criteria.

3 Availability criterion

Complementing the available evidence above (§2), a simplified approach consists on valuing based on the maximum bearable duration of non-accessibility to the informational Asset. This duration is defined in the table below. If the informational Asset is a system, the evaluation has to take into account the means of substitution already existing.

D	Maximum tolerable duration of non-accessibility of Informational Assets
1	+ than 48 Hours
2	Between 12 hours and 48 hours
3	Between 4 hours and 12 hours
4	- than 4 hours

4 Integrity Criterion

Based on the above available scale (§2), this criterion is analyzed in view of the importance of resources in the identical replacement or to the resetting of Informational Assets subject to alteration, destruction, disappearance, as well as with respect to consecutive immaterial damages (such as loss of production, of profit, etc…).

5 Confidentiality criterion

The table below obtained from the operating rule « Control of sensitive information », mentions the impact of the four selected levels and specifies access restrictions to this information to implement. This formulation can be complemented by the highest available scale (§2) whenever necessary.

C	**Level of financial consequences or other for disclosure of information** **Level of accessibility to information**
Level 1 **Non Sensitive**	Disclosing the information would have no effect or injury for the Group. Information may be accessed without restriction.
Level 2 **PSA Sensitive**	Disclosing the information would have a perceptible impact for the Group (disclosure of intellectual property, short-term damage to image, incorrect interpretation by a third party, etc.). The information is only accessible to persons within PSA or those outside it and are participating in the Group's activities.
Level 3 **PSA Confidential**	Disclosure of the information would have a critical impact for the Group (loss of competitive elements, regulatory breach, significant loss of image or trust, etc.). The information is only accessible to a limited number of persons identified by name or role in the Group's activities.
Level 4 **PSA Secret**	Disclosure of the information would have a crippling impact on the Group and particularly on its strategy (loss of a major competitive advantage, breakdown in priority business relations, etc.). Information is only accessible to a very limited number of named persons, under the strict control of the information's owner.

6 Traceability criterion

6.1 Explanation

This criterion is analyzed from the level of surveillance needs and the functional control and the use of Informational Assets. It provides in particular evidence elements that can be used for audit purposes (users identity, nature and sequence of works...) or else information used to detect the occurrence of a functional abnormality.

In terms of information system, traceability constitutes a functional requirement made available of a project manager on the basis of expression required.

T	Requirements
1	The exploitation afterwards of standard IT logs is sufficient to meet the need for traceability.
2	The needs for surveillance and control are **operational requirements** that impose a systematic action (periodic publication or onto event of a state of certain actions or situations): then it is therefore necessary to form and maintain data (date, hour, identities, etc…).
3	The needs for surveillance and control are **operational requirements of high level or regulatory** that impose a systematic action (periodic publication or onto event of a state of certain actions or situations): then it is therefore necessary to form and maintain data (date, hour, identities, and…).
4	The needs for surveillance and control are **operational requirements of very high level or regulatory** that impose a systematic action (periodic publication or onto event of a state of certain actions or situations): then it is therefore necessary to form and maintain data (date, hour, identities, and…) **and preserve its integrity.**

6.2 Help for the valorization of the Traceability criterion

Apart from the legal constraints that impose the value T=4, the level of traceability is linked to the challenges of the treatments or of the applications: an appropriate evaluation by the job is therefore necessary.

Outside the legal context, the notion of traceability is within the scope:

- of the quality control or of the deterrence,
- of the improvement of the data management processes,
- of the reduction of impact following the realization of a “sinister”,
- of the analysis of incidents.

Are likely to be classified T=3 or T=4:

- Treatments or applications in which we want to preserve:

- from fraud,
- from the erroneous use of financial data,
- from the losses of financial transactions;
- …

- Treatments or applications where you want to:

- track changes in parameters (ex: Process of fabrication, of metrology, etc...),

- recuperate the deleted data,
- demonstrate that contacts or actions were made (ex: environmental regulation, bank regulation),
- prove the existence of illegal actions (access, modification, access time slots, etc...),
- establish that a site with illegal content has been visited,
- establish the origins of malicious actions or not,
- follow the attributions of access rights (direct attribution, or modification access control lists in the application),
- follow the modifications for computer programs for the treatments;
- …

- Treatments or applications where one of the components of the DIC is equal to 4:

- Monitoring copies of data (ex: Products vehicle Plan etc…),
- Access list in reading (ex: Access to the medical files, HR, etc...),
- Monitoring of data changes (ex: data for the settlement: bank details of suppliers, changes of parameters for Payroll, personal data, etc...).

7 Consideration of personal data

The **GDPR**[1] regulation requires the protection of all personal data processed by the Group. This data relating to privacy is referred to in the remainder of the document as **PD** [2].

The French law transposed from the European Directive in force as well as any additional requirements specific to the laws of the countries where the PDs are collected should be applied.

This directive specifies the technical and organisational measures to be implemented to satisfy the need for information system security expected for an application in everyday life; this need is summarised by the value given to the Availability, Integrity, Confidentiality and Traceability criteria at the end of a risk analysis validated by a Steering Committee (CO).

The PSA Group is very careful to respect the privacy and the protection of personal data.

The protection of these data is subject to different legal or regulatory requirements for their processing. For the processing implemented by the Group, it is necessary to apply at least the European GDPR regulation.

Additional requirements specific to the laws of the countries in which the PDs are collected may be required.

The fulfilement of these requirements is based both on functionalities dedicated to PDs (right to be forgotten, retention period, etc.) and on measures to mitigate the risks for the people concerned, linked to the security of information systems, according to the security needs expected by the Business and defined in the form of a DICT.
When an application processes PDs, it is subject to the GDPR Regulation. The risks for the concerned data subjects have to be assessed in the context of the purposes of the application and the data processed, using the following scale based on the impact matrix on the privacy of individuals.

Risk level		Minimum DICT
A	Negligible	x222
B	Limited	x222
C	Serious	x222
D	Important	x333
E	Severe	x343
F	Maximum	N/A

The minimum value of the DICT[3] can then be formulated as follows:

x222 If there is no risk higher than the "C - Serious" level on all PDs processed by the application;

x333 If there is at least a maximum risk of level "D - Important" on one of its PDs;

x343 If there is at least an "E - Severe" risk on any of its PDs;

If necessary, the calculation of the DICT is adjusted to a higher value to reflect the most structuring security needs, whether they are induced by GDPR requirements or standard risks.

$$DICT = \max(DICT_{STANDARD_RISKS}, DICT_{GDPR})$$

[1] General Data Protection Regulation (en français, RGPD : Règlement Général sur la Protection des Données - référence : 2016/679)

[2] Personal Data (data relating to private life)

[3] $DICT_{MIN_GDPR}$

Any request for derogation on the quotation to be applied must be addressed to the DPO, who will provide advice to adjust the quotation according to the specificities of the application (nature of the data, purpose of the processing, context, etc ...).

In addition to the standard risk reduction measures (see PSA-DSSI_04) non-functional requirements DP-MD18-EN (see NFR 1.4 « compliance ») will apply to fulfil GDPR requirements.

To go further in the analysis of the risks specific to an IT processing of personal data, the Data Processing Managers or the MOA Project Managers can consult the **I**nternal **C**ontrol and **R**isk **M**anager (liste) or the entity GDPR relay (liste) and use the guidelines « DPIA User's Manual » based on the Commission Nationale de l'Informatique et des Libertés (CNIL) tool in order to facilitate risk management approaches.

8 References

- Operating rule « Monitoring of sensitive data »
- Referential « The Risk Management Device of the Group »
- PSA-DSSI_04: Standard Measures for risk reduction
- «DPIA » guide

9 Reviews

Date	Approver	Changes
	A. Beligné	Put into STSSI format of the earlier directive of SG/DGCR
01/12/2014	M.Oueriagli	Consideration of personal data and reference to the DAMR Device of risk management
30/06/2016	M Oueriagli	Update acronym
01/02/2018	M.Oueriagli	At the request of the internal control explicit request of a T to 3 or 4 for the risk of financial fraud
16/07/2018	H. Moufakkir	Reduction of diversity for the I & C cotation for personal data (I and C at least 3 for applications using this kind of data)
15/04/2019	H. Moufakkir	minimally rated T = 2 any application that contains the PPD
25/02/2021	T. Hec	Evolution of the calculation of the DICT according to the specific risk assessment of privacy data and GDPR requirements
08/03/2021	F. Girard	Updating of the confidentiality criteria grid (§5) to be consistent with the confidentiality classification directive.